Stewer Gabriel

DOCUMENTAÇÃO DO SISTEMA

Segurança

Os controles pelo OWASP Top 10 e onde cada um é testado.

Site e painel de stewergabriel.com
Visagismo e consultoria de imagem · Palmas, Tocantins · Desenvolvido por Gustavo Dev

Versão 2.2.0
08 de novembro de 2026

STEWER GABRIEL

Segurança

Os controles pelo OWASP Top 10 e onde cada um é testado.

Como avisar de uma falha

Achou uma vulnerabilidade? Não abra uma issue pública. Use o aviso privado de vulnerabilidade do GitHub, com o passo a passo para reproduzir. A resposta sai em até 7 dias.

Superfície

PARTE	QUEM ACESSA	O QUE GUARDA
site (`/`)	qualquer pessoa	nada: só lê `/api/conteudo`
painel (`/admin`)	só quem tem acesso, com senha	sessão em cookie `HttpOnly`
API (`/api/admin/*`)	só o painel, da mesma origem	conteúdo do site, fotos, pessoas com acesso, auditoria
banco (Cloudflare D1)	só a API, por binding	nunca exposto na internet

Controles, pelo OWASP Top 10 (2021)

Cada controle tem teste automatizado; a CI roda tudo a cada push.

RISCO	CONTROLE	TESTADO EM
A01 Controle de acesso	toda rota do painel exige sessão; acesso removido vale na hora; senha temporária só libera a troca; id de rota só aceita dígitos	`02-autenticacao` (50 rotas), `11-sessao`, `13-entradas`
A02 Criptografia	PBKDF2-SHA256 com 100 mil iterações e salt por pessoa; comparação em tempo constante; HSTS	`auth.test`, `02-autenticacao`, `12-cabecalhos`
A03 Injeção	SQL sempre por bind, tabelas de lista fechada; React escapa todo texto; CSP sem script inline	`10-sql-injection` (215 casos), `09-seguranca`, `seguranca.spec`
A04 Design inseguro	trava de 5 tentativas por e-mail; mesma mensagem para e-mail inexistente; concorrência por versão	`02-autenticacao`, `07-concorrencia`

RISCO	CONTROLE	TESTADO EM
A05 Configuração	CSP, `nosniff`, `X-Frame-Options`, COOP, Permissions-Policy; painel fora do Google; rota de API inexistente responde 404 em JSON	`12-cabecalhos`, `seguranca.spec`, fiscal da CSP em todos os E2E
A06 Componentes vulneráveis	`npm audit` bloqueia a CI; Dependabot semanal; CodeQL	`.github/workflows`
A07 Autenticação	JWT só HS256 (recusa `alg: none`); sessão gravada no banco, encerrada por "Sair", troca de senha e senha temporária; cookie `HttpOnly` + `SameSite=Strict`	`auth.test`, `11-sessao`, `seguranca.spec`
A08 Integridade	campo que o painel não manda não é gravado (mass assignment); upload conferido pelos bytes	`13-entradas`, `04-fotos`
A09 Registro	auditoria de quem mudou o quê, com data; tentativas de login com IP	`08-usuarios-auditoria`
A10 SSRF	o link do mapa só é aberto se for do Google, por HTTPS, sem usuário nem porta, no máximo 6 saltos	`link-mapa.test`, `13-entradas`

CSRF: o cookie é `SameSite=Strict` e, além disso, todo pedido que muda dado precisa vir da mesma origem (`09-seguranca`).

Fora do alcance

- Ataques de volume (DDoS): ficam com a Cloudflare, na frente de tudo.
- Quem já tem a senha do painel: por isso existe a auditoria e o "Sair".
- O `JWT_SECRET` vazado não basta para entrar: o token precisa apontar para uma sessão aberta no banco (`11-sessao`).

Rodar só a segurança

```
npm run build
npm run test:seguranca   # API (OWASP) + navegador
npm run auditoria        # dependências
```